

SEGURANÇA DE REDES DE COMPUTADORES

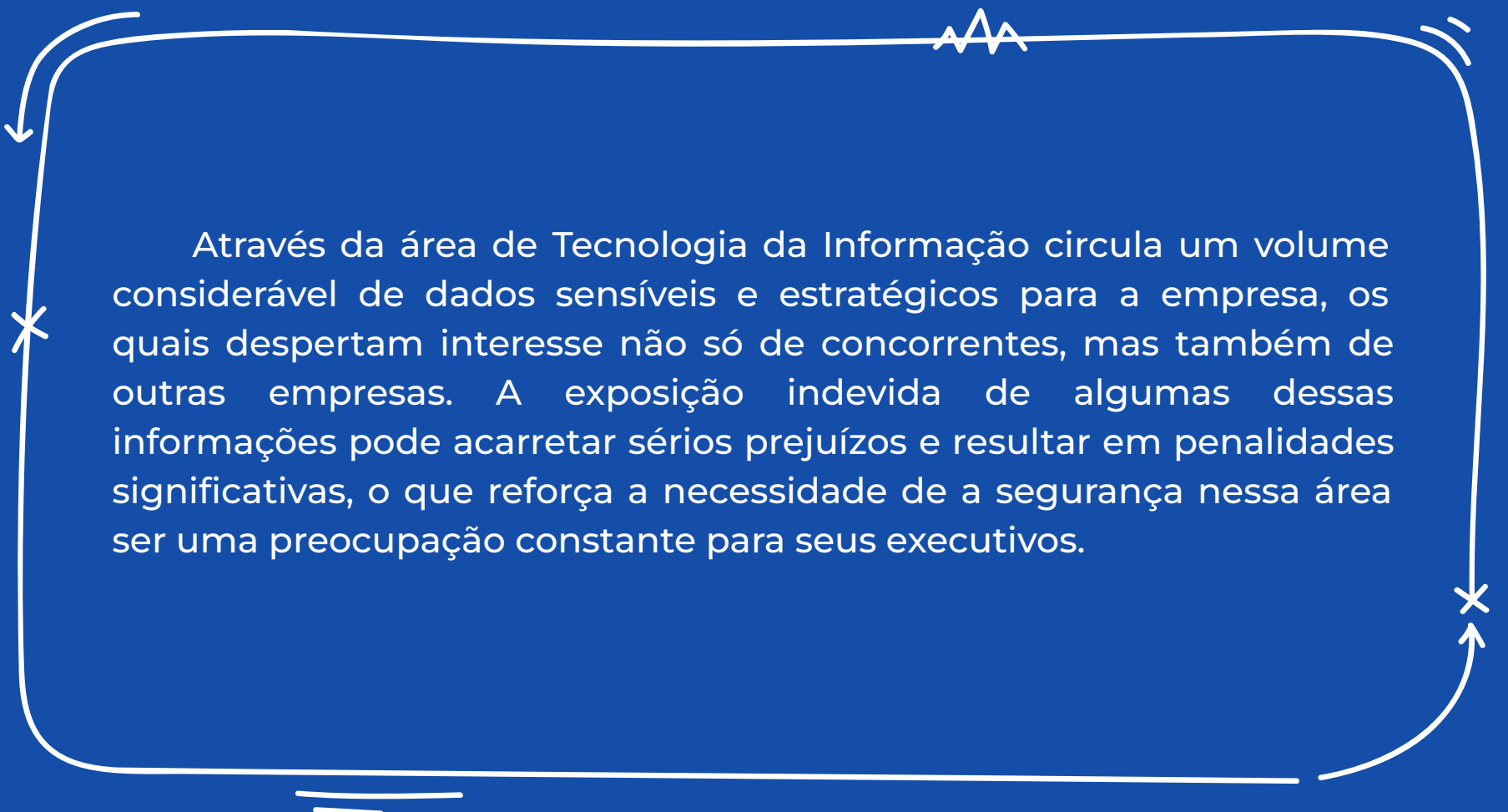


SEGURANÇA LÓGICA



Segurança Lógica

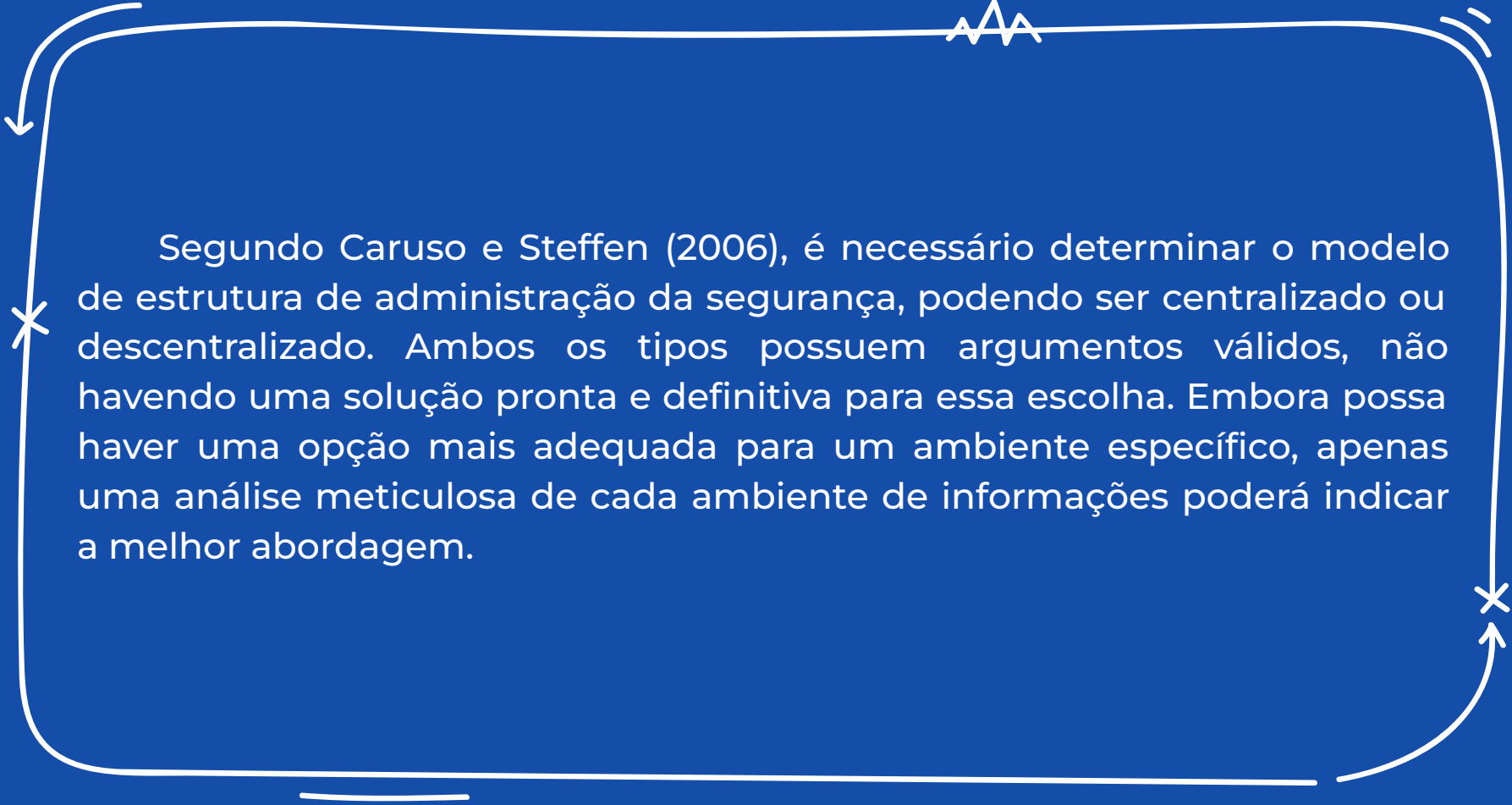
As informações de uma empresa possuem valor não apenas para a própria organização, mas também para concorrentes, suscitando preocupações sobre espionagem empresarial, e para outras entidades, como cadastros de clientes e listas de produtos, entre outros. Portanto, a atenção à segurança da informação deve ser uma constante em todos os setores, destacando-se a importância na área de Tecnologia da Informação (FOINA, 2013).



Através da área de Tecnologia da Informação circula um volume considerável de dados sensíveis e estratégicos para a empresa, os quais despertam interesse não só de concorrentes, mas também de outras empresas. A exposição indevida de algumas dessas informações pode acarretar sérios prejuízos e resultar em penalidades significativas, o que reforça a necessidade de a segurança nessa área ser uma preocupação constante para seus executivos.

O próximo passo na implementação da estrutura de segurança, imediatamente após estabelecer as **diretrizes da política de segurança**, é a definição da configuração da administração de segurança. Deve-se levar em consideração elementos como o formato da administração de segurança, o tipo de estrutura, sua posição na hierarquia organizacional, os requisitos de perfil para o profissional que assumirá a função de administrador de segurança, as orientações de segurança, o conjunto de ferramentas administrativas e técnicas empregadas, a equipe encarregada de executar a implementação da segurança, o nível de padronização requerido, entre outros (CARUSO; STEFFEN, 2006).

Um dos primeiros passos a serem ponderados após a determinação das diretrizes é a configuração da administração de segurança. Deve-se estabelecer uma estrutura que, ao término da implementação do projeto de segurança, ficará encarregada das rotinas habituais de administração do ambiente de informações, abarcando tanto o aspecto físico quanto o lógico. É essencial delinear com clareza sua esfera de influência, autoridade e os princípios que nortearão suas operações (CARUSO; STEFFEN, 2006; GROSS; GROSS, 2013).



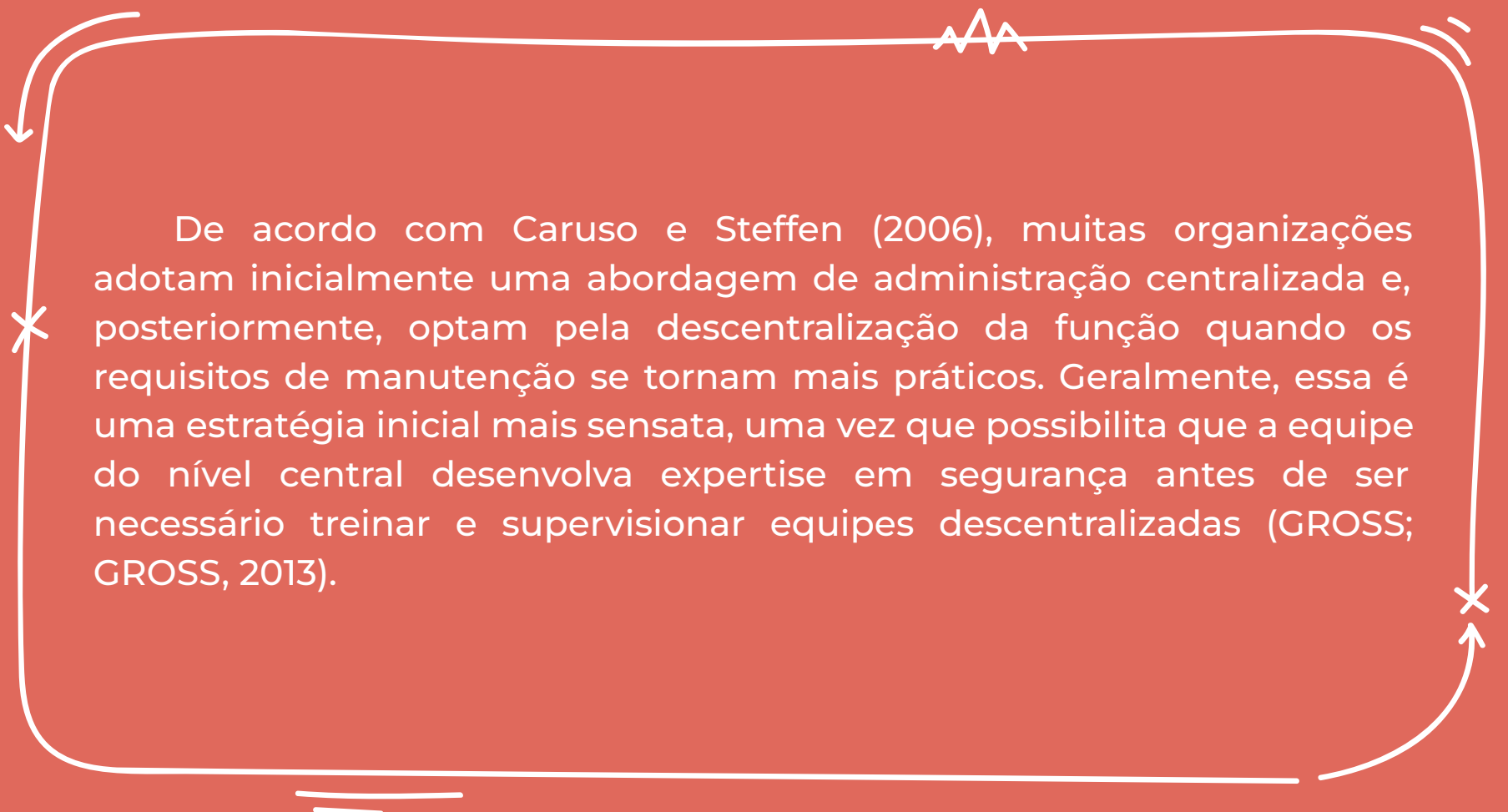
Segundo Caruso e Steffen (2006), é necessário determinar o modelo de estrutura de administração da segurança, podendo ser centralizado ou descentralizado. Ambos os tipos possuem argumentos válidos, não havendo uma solução pronta e definitiva para essa escolha. Embora possa haver uma opção mais adequada para um ambiente específico, apenas uma análise meticulosa de cada ambiente de informações poderá indicar a melhor abordagem.

A seguir serão listados alguns pontos que devem ser considerados no processo de tomada de decisão quanto ao tipo de estrutura, veja as vantagens e desvantagens sobre a **centralização da estrutura**:

Vantagens	Desvantagens
Maior simplificação organizacional e de procedimentos.	Menor grau de flexibilidade.
Especialistas de segurança dedicados.	Desconhecimento de condições locais.
Menor dispersão de esforços.	Custo maior concentrado em uma única área.
Menor sobreposição de estruturas de segurança.	Tempo de resposta mais lento.
Maior rapidez de manutenção.	

Vantagens e desvantagens da descentralização:

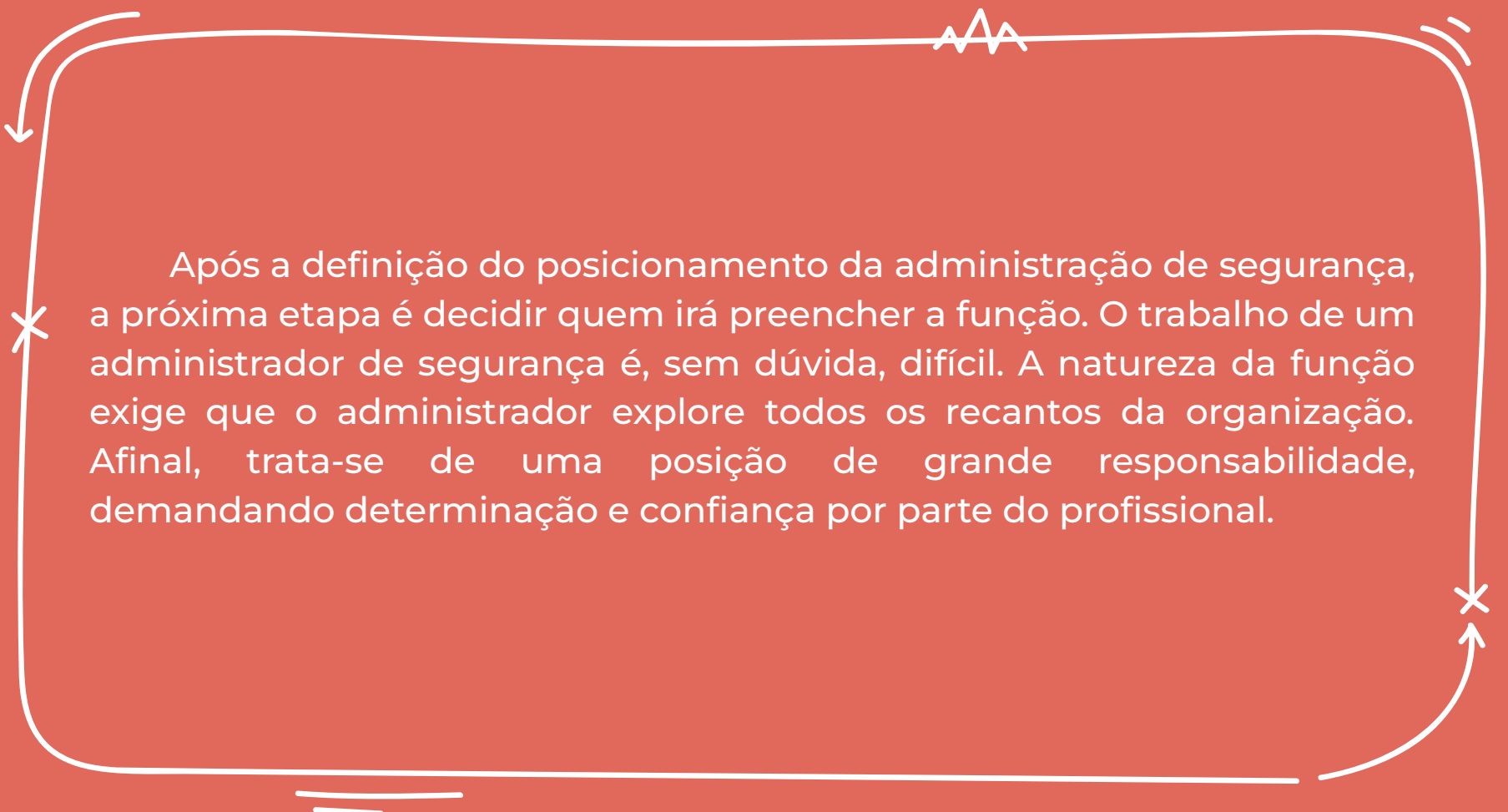
Vantagens	Desvantagens
Maior flexibilidade.	Aumento da burocracia.
Manutenção local mais rápida.	Maior sobreposição de estruturas de segurança.
Maior familiaridade com as exigências locais.	Menor conhecimento da segurança.
Responsabilidade e relacionamento distribuídos.	Maior suscetibilidade a pressões locais.
	Maiores dificuldades de controle por parte da auditoria ou outro órgão de controle.



De acordo com Caruso e Steffen (2006), muitas organizações adotam inicialmente uma abordagem de administração centralizada e, posteriormente, optam pela descentralização da função quando os requisitos de manutenção se tornam mais práticos. Geralmente, essa é uma estratégia inicial mais sensata, uma vez que possibilita que a equipe do nível central desenvolva expertise em segurança antes de ser necessário treinar e supervisionar equipes descentralizadas (GROSS; GROSS, 2013).

É melhor que o administrador de segurança esteja envolvido desde o início da implantação da estrutura de segurança, segundo Caruso e Steffen (2006). Dessa forma, o administrador será capaz de gerenciar as tarefas diárias e constantes. Ainda mais, a administração de segurança não deve ser vinculada a nenhuma das áreas de informática, uma vez que estas também são beneficiárias dos protocolos de segurança. (CARUSO; STEFFEN, 2006). A área de auditoria também não pode ser ligada a administração da segurança, pois cabe a ela fiscalizar esta área.

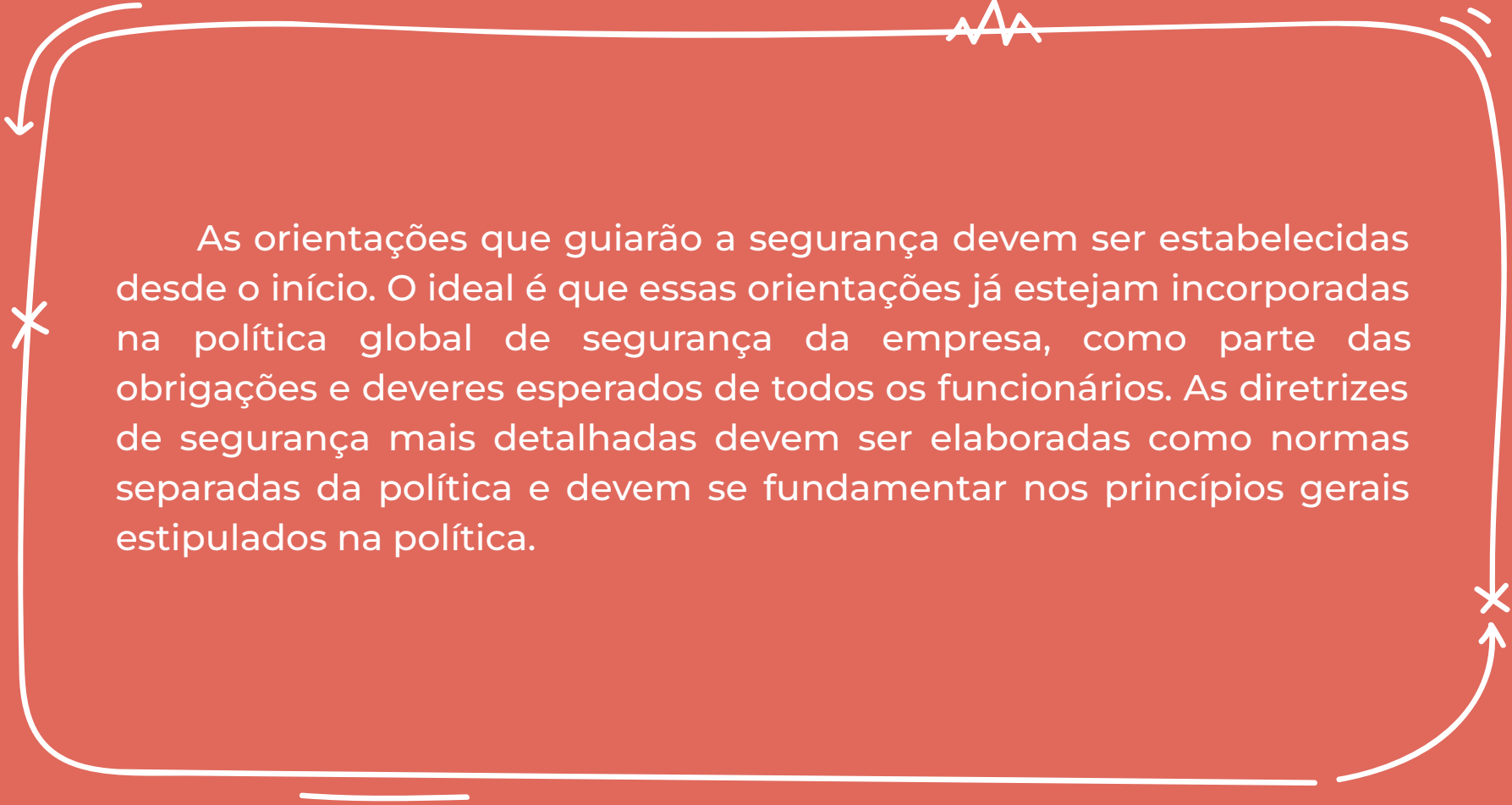
Recomenda-se que a definição da estrutura de segurança esteja incluída na política de segurança, pelo menos em seus contornos gerais. Segundo Caruso e Steffen (2006), é aconselhável posicioná-la, pelo menos em termos de hierarquia, juntamente com a estrutura de segurança empresarial, responsável pela segurança das organizações em um contexto mais amplo, caso essa estrutura exista na empresa. Como várias outras estruturas nas organizações, esse tipo de configuração está diretamente relacionado ao porte de cada organização.



Após a definição do posicionamento da administração de segurança, a próxima etapa é decidir quem irá preencher a função. O trabalho de um administrador de segurança é, sem dúvida, difícil. A natureza da função exige que o administrador explore todos os recantos da organização. Afinal, trata-se de uma posição de grande responsabilidade, demandando determinação e confiança por parte do profissional.

Entre as várias qualidades que um possível administrador de segurança deve possuir, destacam-se (CARUSO; STEFFEN, 2006; GROSS; GROSS, 2013):

- Conhecimento dos recursos dos ambientes de informações e dos requisitos de segurança adequados;
- Alto grau de responsabilidade;
- Boa experiência organizacional e em análises;
- Sensibilidade para a política do ambiente de informações;
- Facilidade em se relacionar, pois a maior parte do trabalho envolve convencer as pessoas;
- Estabilidade emocional.



As orientações que guiarão a segurança devem ser estabelecidas desde o início. O ideal é que essas orientações já estejam incorporadas na política global de segurança da empresa, como parte das obrigações e deveres esperados de todos os funcionários. As diretrizes de segurança mais detalhadas devem ser elaboradas como normas separadas da política e devem se fundamentar nos princípios gerais estipulados na política.

Em princípio, as diretrizes de segurança devem abranger os seguintes aspectos (CARUSO; STEFFEN, 2006):

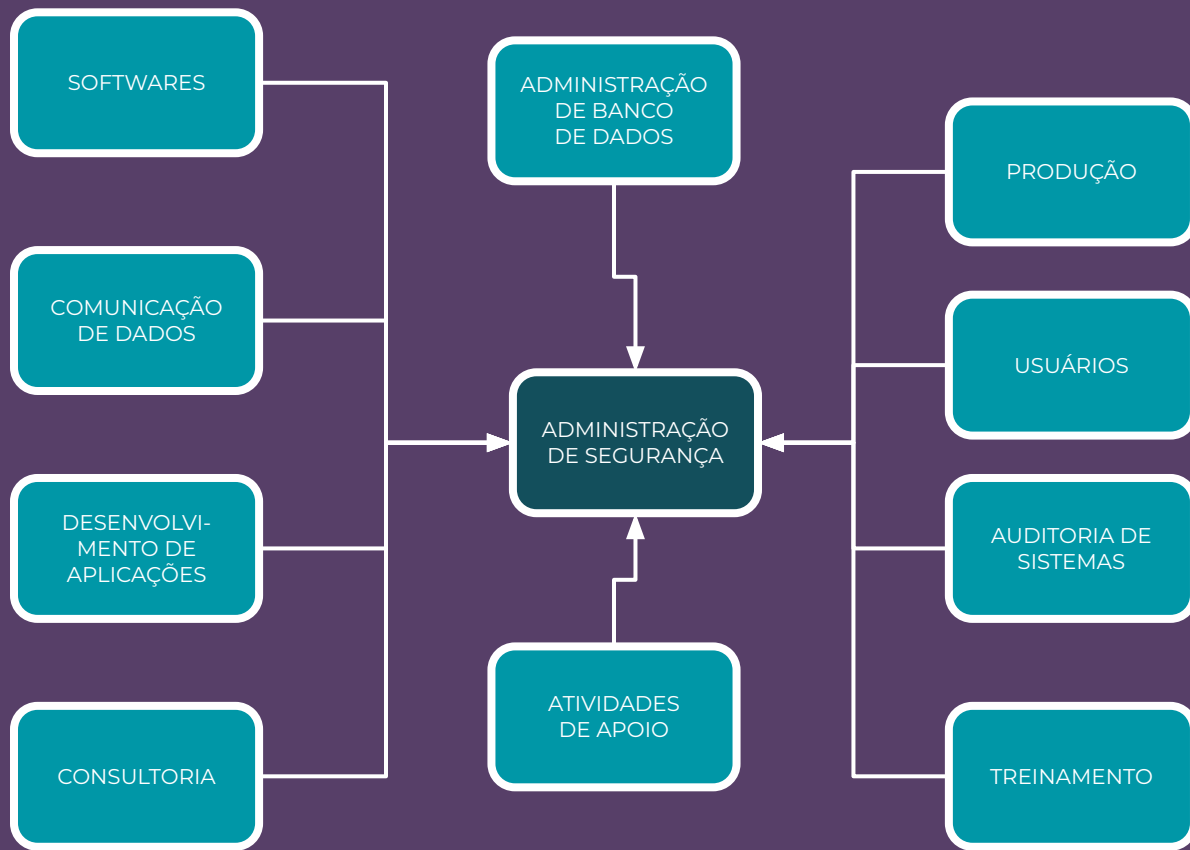
- Documentação dos controles de segurança disponíveis para cada tipo de recurso e a comunicação a todos os envolvidos;
- Procedimentos padrões de segurança que serão utilizados no ambiente de trabalho na empresa;
- Estimativa dos riscos e comprometimentos dentro do ambiente da empresa. Registro e relato das violações para as pessoas indicadas;
- Acompanhamento do desenvolvimento de requisitos de segurança para todos os projetos dos usuários;
- Treinamento de todos os usuários com relação à política de segurança da empresa;
- Se for necessário, apoio às administrações descentralizadas e seu controle;
- Responsabilização dos envolvidos com a função de segurança, desde o administrador central até o usuário final.

Normalmente serão necessários relatórios de controle de dois tipos: **controle da estrutura de segurança e controle sobre atividades de usuários**. Os relatórios de controle da estrutura destinam-se a controlar os usuários, os recursos e as interações entre usuários e recursos (CARUSO; STEFFEN, 2006; GROSS; GROSS, 2013).

- **Usuários e grupos de usuários:** Estrutura hierárquica dos grupos de usuários; Usuários de cada grupo; Usuários com atributos especiais.
- **Recursos:** Grupos de recursos protegidos; Recursos de cada grupo; Nível de proteção de cada grupo de recurso; Nível de proteção de cada recurso individual; Recursos com proteção especial.
- **Interações usuários versus recursos:** Recurso que cada usuário pode acessar; Usuários que acessam cada recurso; Nível de acesso permitido a cada grupo / usuário.

A equipe do projeto deve ser formada por membros provenientes das áreas que serão mais impactadas pela estrutura de segurança. Essa abordagem decorre da necessidade de atender aos requisitos de segurança de todos os envolvidos. O objetivo principal desse engajamento é cultivar um senso de participação e responsabilidade coletiva no resultado final da segurança.

Modelo de estrutura de equipe para projeto de segurança de acesso lógico



Em princípio, ainda segundo Caruso e Steffen (1999, p. 118), a equipe do projeto deve ser composta com elementos das seguintes áreas:

- **Administração de segurança** – O administrador de segurança coordena o projeto, com a possibilidade de contar com a equipe de segurança para apoio operacional;
- **Software básico e de apoio** – Responsável pelo ferramental de informática, incluindo a implementação e adaptação da ferramenta de segurança ao ambiente operacional;
- **Administração de dados** – Gerencia os ativos de informação nos computadores, operacionaliza softwares de banco de dados e preserva a integridade dos dados em bancos de dados;

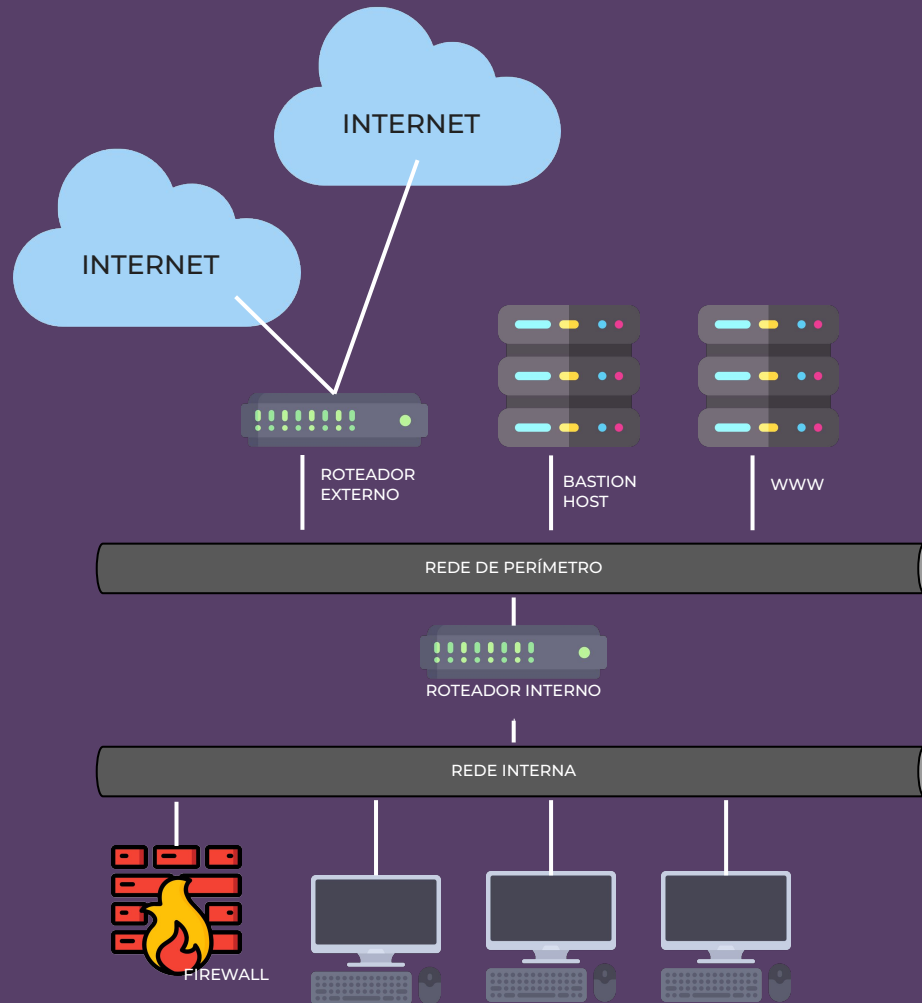
- **Produção** – Em organizações com processamento centralizado, esta área é encarregada do processamento dos serviços de informática;
- **Comunicação de dados e redes** – Lida com a comunicação de dados, considerando os riscos associados à interceptação e os requisitos de segurança específicos;
- **Desenvolvimento de aplicações** – Responsável pelos recursos de desenvolvimento, incluindo normatização e estabelecimento de padrões de segurança para aplicativos;
- **Auditoria** – Controla o uso dos ativos em nome dos proprietários, garantindo a adesão às normas e procedimentos estabelecidos;

- **Usuários** – A segurança deve preservar a integridade dos ativos sem causar transtornos aos usuários finais, para quem as atividades de processamento são realizadas;
- **Treinamento** – Implica em treinamento extensivo relacionado aos requisitos de segurança, podendo contar com assessoria de especialistas em treinamento;
- **Atividades de apoio** – Podem ser necessárias para situações que não estejam diretamente ligadas às atividades de informação, como administração patrimonial, transporte, comunicações, entre outras;
- **Consultoria externa** – Considera a possibilidade de envolver consultores externos, fornecedores de equipamentos e ferramentas de segurança para complementar os esforços internos da equipe.

Assim como na segurança física, a segurança lógica também se beneficia de barreiras criadas em torno de um ativo ou conjunto de ativos de informação que se deseja proteger (BEAL, 2008).

Uma defesa de perímetro é sempre um bom primeiro passo na proteção, e firewalls de rede, mecanismos de controle de acesso, dispositivos confiáveis de autenticação, VPNs, antivírus e *bastion hosts* (gateways instalados entre uma rede interna e o ambiente externo para protegê-la de ataques) são exemplos de barreiras que podem ser usadas no estabelecimento de um perímetro de segurança de rede.

A criação de uma segurança lógica eficiente é um desafio devido à complexidade de identificar todas as vulnerabilidades que poderiam expor a rede a ataques. As redes de perímetro, também conhecidas como **zonas desmilitarizadas (DMZ)**, desempenham o papel de proteger um computador ou segmento de rede posicionado entre uma rede interna (como uma LAN privativa) e uma rede externa não confiável, como a internet. A DMZ atua como uma zona intermediária para o tráfego de entrada e saída. Este termo tem raízes militares, referindo-se a uma área neutra que separa dois adversários (BEAL, 2008).



Referências

BEAL, A. Segurança da informação: princípios e melhores práticas para a proteção dos ativos de informação nas organizações. [s.l.] São Paulo: Atlas, 2008.

CARUSO, C. A. A.; STEFFEN, F. DENY. Segurança em informática e de informações. 4. ed. [s.l.] Senac São Paulo, 2006.

FERREIRA, F. N. F.; ARAÚJO, M. T. DE. Política de segurança da informação guia prático para elaboração e implementação. 2. ed. Rio de Janeiro: Ciência Moderna, 2008.

FIPS PUB 199. Standards for Security Categorization of Federal Information and Information Systems. 2004. [s.l: s.n.]. Disponível em: <<https://csrc.nist.gov/pubs/fips/199/final>>.

FOINA, P. ROGÉRIO. Tecnologia De Informação: Planejamento E Gestão. 3. ed. [s.l.] Atlas, 2013.

FRANCISCATTO, R.; DE CRISTO, F.; PERLIN, T. Redes de Computadores. Frederico Westphalen: UFSM, 2014.

GROSS, C. M.; GROSS, J. C. Segurança em Tecnologia da informação. [s.l.] UNIASSELVI, 2013.

GUTTMAN, B.; ROBACK, E. An Introduction to Computer Security: the NIST Handbook. Special Publication (NIST SP), National Institute of Standards and Technology, Gaithersburg, MD, out. 1995.

KLUSAITĖ, L. A história da segurança cibernética. 2022. Disponível em: <<https://nordvpn.com/pt-br/blog/historia-seguranca-cibernetica/>>.

MACEDO, M. Introdução à Segurança da Informação Corporativa. Pernambuco: 2021 [s.n.].

NAKAMURA, E. T.; GEUS, P. L. Segurança de Redes em Ambientes Cooperativos. [s.l.] Novatec, 2007.

NBR ISO/IEC 17799. Tecnologia da informação - Código de prática para a gestão da segurança da informação. Rio de Janeiro, ABNT, 2001.

PRASAD, R.; ROHOKALE, V. Cyber Security: The Lifeline of Information and Communication Technology. Cham: Springer International Publishing, 2020.

WHITMAN, M. E.; MATTORD, H. J. Management of Information Security. 4. ed. [s.l.] Cengage Learning, 2013.

Professor Autor

Evandro Luis da Rosa

Professora Revisora

Taís Belzarena

Designer Instrucional

Ricardo Andrade Lopes

Design Gráfico

Helena Dias

Ilustrações

Adobe Stock

Envato Elements

Flaticon

Freepik

Storyset

Proibida a reprodução total ou parcial, sem autorização.
Lei de Direitos Autorais nº 9610/98.